Control Evidence Tracker - Control Details and Implementation

Control Number	Control Title	Control description	Status	Implementation Status
5.1	Policies for information security	Information security policy and topic-specific policies shall be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.	Planned	To be determined
5.2	Information security roles and responsibilities	Information security roles and responsibilities shall be defined and allocated according to the organisation needs.	Planned	To be determined
5.3	Segregation of duties	Conflicting duties and conflicting areas of responsibility shall be segregated.	Planned	To be determined
5.4	Management responsibilities	Management shall require all personnel to apply information security in accordance with the established information security policy, topic-specific policies and procedures of the organisation.	Planned	To be determined
5.9	Inventory of information and other associated assets	An inventory of information and other associated assets, including owners, shall be developed and maintained	Planned	To be determined
5.10	Acceptable use of information and other associated assets	Rules for the acceptable use and procedures for handling information and other associated assets shall be identified, documented and implemented.	Planned	To be determined
5.11	Return of assets	Personnel and other interested parties as appropriate shall return all the organisation's assets in their possession upon change or termination of their employment, contract or agreement.	Planned	To be determined
5.12	Classification of information	Information shall be classified according to the information security needs of the organisation based on confidentiality, integrity, availability and relevant interested party requirements.	Planned	To be determined
5.13	Labelling of information	An appropriate set of procedures for information labelling shall be developed and implemented in accordance with the information classification scheme adopted by the organisation.	Planned	To be determined

Control Number	Control Title	Control description	Status	Implementation Status
5.14	Information transfer	Information transfer rules, procedures, or agreements shall be in place for all types of transfer facilities within the organisation and between the organisation and other parties.	Planned	To be determined
5.15	Access control	Rules to control physical and logical access to information and other associated assets shall be established and implemented based on business and information security requirements.	Planned	To be determined
5.16	Identity management	The full life cycle of identities shall be managed.	Planned	To be determined
5.17	Authentication information	Allocation and management of authentication information shall be controlled by a management process, including advising personnel on appropriate handling of authentication information.	Planned	To be determined
5.18	Access rights	Access rights to information and other associated assets shall be provisioned, reviewed, modified and removed in accordance with the organisation's topic-specific policy on and rules for access control.	Planned	To be determined
5.19	Information security in supplier relationships	Processes and procedures shall be defined and implemented to manage the information security risks associated with the use of supplier's products or services.	Planned	To be determined
5.20	Addressing information security within supplier agreements	Relevant information security requirements shall be established and agreed with each supplier based on the type of supplier relationship.	Planned	To be determined
5.23	Information security for use of cloud services	Processes for acquisition, use, management and exit from cloud services shall be established in accordance with the organisation's information security requirements.	Planned	To be determined
5.24	Information security incident management planning and preparation	The organisation shall plan and prepare for managing information security incidents by defining, establishing and communicating information security incident management processes, roles and responsibilities.	Planned	To be determined

Control Number	Control Title	Control description	Status	Implementation Status
5.25	Assessment and decision on information security events	The organisation shall assess information security events and decide if they are to be categorised as information security incidents.	Planned	To be determined
5.26	Response to information security incidents	Information security incidents shall be responded to in accordance with the documented procedures.	Planned	To be determined
5.27	Learning from information security incidents	Knowledge gained from information security incidents shall be used to strengthen and improve the information security controls.	Planned	To be determined
5.28	Collection of evidence	The organisation shall establish and implement procedures for the identification, collection, acquisition and preservation of evidence related to information security events.	Planned	To be determined
5.29	Information security during disruption	The organisation shall plan how to maintain information security at an appropriate level during disruption.	Planned	To be determined
5.30	ICT readiness for business continuity	ICT readiness shall be planned, implemented, maintained and tested based on business continuity objectives and ICT continuity requirements.	Planned	To be determined
5.31	Legal, statutory, regulatory and contractual requirements	Legal, statutory, regulatory and contractual requirements relevant to information security and the organisation's approach to meet these requirements shall be identified, documented and kept up to date.	Planned	To be determined
5.35	Independent review of information security	The organisation's approach to managing information security and its implementation including people, processes and technologies shall be reviewed independently at planned intervals, or when significant changes occur.	Planned	To be determined
5.36	Compliance with policies, rules and standards for information security	Compliance with the organisation's information security policy, topic-specific policies, rules and standards shall be regularly reviewed.	Planned	To be determined

Control Number	Control Title	Control description	Status	Implementation Status
6.1	Screening	Background verification checks on all candidates to become personnel shall be carried out prior to joining the organisation and on an ongoing basis taking into consideration applicable laws, regulations and ethics and be proportional to the business requirements, the classification of the information to be accessed and the perceived risks.	Planned	To be determined
6.2	Terms and conditions of employment	The employment contractual agreements shall state the personnel's and the organisation's responsibilities for information security.	Planned	To be determined
6.3	Information security awareness, education and training	Personnel of the organisation and relevant interested parties shall receive appropriate information security awareness, education and training and regular updates of the organisation's information security policy, topic-specific policies and procedures, as relevant for their job function.	Planned	To be determined
6.4	Disciplinary process	A disciplinary process shall be formalised and communicated to take actions against personnel and other relevant interested parties who have committed an information security policy violation	Planned	To be determined
6.5	Responsibilities after termination or change of employment	Information security responsibilities and duties that remain valid after termination or change of employment shall be defined, enforced and communicated to relevant personnel and other interested parties.	Planned	To be determined
6.6	Confidentiality or non-disclosure agreements	Confidentiality or non-disclosure agreements reflecting the organisation's needs for the protection of information shall be identified, documented, regularly reviewed and signed by personnel and other relevant interested parties.	Planned	To be determined
6.7	Remote working	Security measures shall be implemented when personnel are working remotely to protect information accessed, processed or stored outside the organisation's premises.	Planned	To be determined
6.8	Information security event reporting	The organisation shall provide a mechanism for personnel to report observed or suspected information security events through appropriate channels in a timely manner.	Planned	To be determined

Control Number	Control Title	Control description	Status	Implementation Status
8.1	User end point devices	Information stored on, processed by or accessible via user end point devices shall be protected.	Planned	To be determined
8.2	Privileged access rights	The allocation and use of privileged access rights shall be restricted and managed.	Planned	To be determined
8.3	Information access restriction	Access to information and other associated assets shall be restricted in accordance with the established topic-specific policy on access control.	Planned	To be determined
8.4	Access to source code	Read and write access to source code, development tools and software libraries shall be appropriately managed.	Planned	To be determined
8.5	Secure authentication	Secure authentication technologies and procedures shall be implemented based on information access restrictions and the topic-specific policy on access control.	Planned	To be determined
8.6	Capacity management	The use of resources shall be monitored and adjusted in line with current and expected capacity requirements.	Planned	To be determined
8.7	Protection against malware	Protection against malware shall be implemented and supported by appropriate user awareness.	Planned	To be determined
8.8	Management of technical vulnerabilities	Information about technical vulnerabilities of information systems in use shall be obtained, the organisation’s exposure to such vulnerabilities shall be evaluated and appropriate measures shall be taken.	Planned	To be determined
8.9	Configuration management	Configurations, including security configurations, of hardware, software, services and networks shall be established, documented, implemented, monitored and reviewed.	Planned	To be determined
8.10	Information deletion	Information stored in information systems, devices or in any other storage media shall be deleted when no longer required.	Planned	To be determined

Control Number	Control Title	Control description	Status	Implementation Status
8.13	Information backup	Backup copies of information, software and systems shall be maintained and regularly tested in accordance with the agreed topic-specific policy on backup.	Planned	To be determined
8.14	Redundancy of information processing facilities	Information processing facilities shall be implemented with redundancy sufficient to meet availability requirements.	Planned	To be determined
8.15	Logging	Logs that record activities, exceptions, faults and other relevant events shall be produced, stored, protected and analysed.	Planned	To be determined
8.16	Monitoring activities	Networks, systems and applications shall be monitored for anomalous behaviour and appropriate actions taken to evaluate potential information security incidents.	Planned	To be determined
8.17	Clock synchronisation	The clocks of information processing systems used by the organisation shall be synchronised to approved time sources.	Planned	To be determined
8.19	Installation of software on operational systems	Procedures and measures shall be implemented to securely manage software installation on operational systems	Planned	To be determined
8.20	Networks security	Networks and network devices shall be secured, managed and controlled to protect information in systems and applications	Planned	To be determined
8.21	Security of network services	Security mechanisms, service levels and service requirements of network services shall be identified, implemented and monitored.	Planned	To be determined
8.22	Segregation of networks	Groups of information services, users and information systems shall be segregated in the organisation’s networks.	Planned	To be determined
8.23	Web filtering	Access to external websites shall be managed to reduce exposure to malicious content.	Planned	To be determined
8.24	Use of cryptography	Rules for the effective use of cryptography, including cryptographic key management, shall be defined and implemented.	Planned	To be determined

Control Number	Control Title	Control description	Status	Implementation Status
8.25	Secure development life cycle	Rules for the secure development of software and systems shall be established and applied.	Planned	To be determined
8.26	Application security requirements	Information security requirements shall be identified, specified and approved when developing or acquiring applications.	Planned	To be determined
8.27	Secure system architecture and engineering principles	Principles for engineering secure systems shall be established, documented, maintained and applied to any information system development activities.	Planned	To be determined
8.28	Secure coding	Secure coding principles shall be applied to software development	Planned	To be determined
8.29	Security testing in development and acceptance	Security testing processes shall be defined and implemented in the development life cycle.	Planned	To be determined
8.31	Separation of development, test and production environments	Development, testing and production environments shall be separated and secured.	Planned	To be determined
8.34	Protection of information systems during audit testing	Audit tests and other assurance activities involving assessment of operational systems shall be planned and agreed between the tester and appropriate management.	Planned	To be determined

Control Evidence Tracker - Evidence and Verification

Control Number	Control Title	Evidence Type	Evidence Location	Responsible Owner	Date Verified	Comments
5.1	Policies for information security	To be determined	To be assigned			
5.2	Information security roles and responsibilities	To be determined	To be assigned			
5.3	Segregation of duties	To be determined	To be assigned			
5.4	Management responsibilities	To be determined	To be assigned			
5.9	Inventory of information and other associated assets	To be determined	To be assigned			
5.10	Acceptable use of information and other associated assets	To be determined	To be assigned			
5.11	Return of assets	To be determined	To be assigned			
5.12	Classification of information	To be determined	To be assigned			
5.13	Labelling of information	To be determined	To be assigned			
5.14	Information transfer	To be determined	To be assigned			
5.15	Access control	To be determined	To be assigned			
5.16	Identity management	To be determined	To be assigned			
5.17	Authentication information	To be determined	To be assigned			
5.18	Access rights	To be determined	To be assigned			

Control Number	Control Title	Evidence Type	Evidence Location	Responsible Owner	Date Verified	Comments
5.19	Information security in supplier relationships	To be determined	To be assigned			
5.20	Addressing information security within supplier agreements	To be determined	To be assigned			
5.23	Information security for use of cloud services	To be determined	To be assigned			
5.24	Information security incident management planning and preparation	To be determined	To be assigned			
5.25	Assessment and decision on information security events	To be determined	To be assigned			
5.26	Response to information security incidents	To be determined	To be assigned			
5.27	Learning from information security incidents	To be determined	To be assigned			
5.28	Collection of evidence	To be determined	To be assigned			
5.29	Information security during disruption	To be determined	To be assigned			
5.30	ICT readiness for business continuity	To be determined	To be assigned			
5.31	Legal, statutory, regulatory and contractual requirements	To be determined	To be assigned			
5.35	Independent review of information security	To be determined	To be assigned			

Control Number	Control Title	Evidence Type	Evidence Location	Responsible Owner	Date Verified	Comments
5.36	Compliance with policies, rules and standards for information security	To be determined	To be assigned			
6.1	Screening	To be determined	To be assigned			
6.2	Terms and conditions of employment	To be determined	To be assigned			
6.3	Information security awareness, education and training	To be determined	To be assigned			
6.4	Disciplinary process	To be determined	To be assigned			
6.5	Responsibilities after termination or change of employment	To be determined	To be assigned			
6.6	Confidentiality or non-disclosure agreements	To be determined	To be assigned			
6.7	Remote working	To be determined	To be assigned			
6.8	Information security event reporting	To be determined	To be assigned			
8.1	User end point devices	To be determined	To be assigned			
8.2	Privileged access rights	To be determined	To be assigned			
8.3	Information access restriction	To be determined	To be assigned			
8.4	Access to source code	To be determined	To be assigned			
8.5	Secure authentication	To be determined	To be assigned			
8.6	Capacity management	To be determined	To be assigned			

Control Number	Control Title	Evidence Type	Evidence Location	Responsible Owner	Date Verified	Comments
8.7	Protection against malware	To be determined	To be assigned			
8.8	Management of technical vulnerabilities	To be determined	To be assigned			
8.9	Configuration management	To be determined	To be assigned			
8.10	Information deletion	To be determined	To be assigned			
8.13	Information backup	To be determined	To be assigned			
8.14	Redundancy of information processing facilities	To be determined	To be assigned			
8.15	Logging	To be determined	To be assigned			
8.16	Monitoring activities	To be determined	To be assigned			
8.17	Clock synchronisation	To be determined	To be assigned			
8.19	Installation of software on operational systems	To be determined	To be assigned			
8.20	Networks security	To be determined	To be assigned			
8.21	Security of network services	To be determined	To be assigned			
8.22	Segregation of networks	To be determined	To be assigned			
8.23	Web filtering	To be determined	To be assigned			
8.24	Use of cryptography	To be determined	To be assigned			
8.25	Secure development life cycle	To be determined	To be assigned			

Control Number	Control Title	Evidence Type	Evidence Location	Responsible Owner	Date Verified	Comments
8.26	Application security requirements	To be determined	To be assigned			
8.27	Secure system architecture and engineering principles	To be determined	To be assigned			
8.28	Secure coding	To be determined	To be assigned			
8.29	Security testing in development and acceptance	To be determined	To be assigned			
8.31	Separation of development, test and production environments	To be determined	To be assigned			
8.34	Protection of information systems during audit testing	To be determined	To be assigned			